Week 12
Information Security Testing and Assessment (Ref: NIST SP 800-115)

(Reference : https://www.nist.gov/privacy-framework/nist-sp-800-115)

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL

(Reference : https://www.nist.gov/privacy-framework/nist-sp-800-115)

Processes and Technical Guidance (P.8/80)

- **Develop** information security assessment policy, methodology, and individual roles and responsibilities related to the technical aspects of assessment
- **Accurately plan** for a technical information security assessment by providing guidance on determining which systems to assess and the approach for assessment, addressing logistical considerations, developing an assessment plan, and ensuring legal and policy considerations are addressed
- **Safely and effectively execute** a technical information security assessment using the presented methods and techniques, and respond to any incidents that may occur during the assessment
- **Appropriately handle** technical data (collection, storage, transmission, and destruction) throughout the assessment process
- **Conduct** analysis and reporting to translate technical findings into risk mitigation actions that will improve the organization's security posture.

Information Security Assessment Methodology (P.12/80)

Information Security Assessment Methodology

- Planning
- Execution
- Post-Execution

Technical Assessment Techniques

- Review Techniques
- Target Identification and Analysis Techniques
- Target Vulnerability Validation Techniques

Testing Viewpoints

- External and Internal
  - External security testing is conducted from outside the organization's security perimeter.
  - Internal testing takes place behind perimeter defenses.
- Overt and Covert
  - Overt security testing (AKA. white hat testing) involves performing external and/or internal testing with the knowledge and consent of the organization's IT staff, enabling comprehensive evaluation of the network or system security posture.
  - Covert security testing (AKA black hat testing) takes an adversarial approach by performing testing without the knowledge of the organization's IT staff but with the full knowledge and permission of upper management.

Review Techniques (P.18/80)

Technique	Capabilities	Baseline Skill Set
Doc. Review	• Evaluates policies and procedures for technical accuracy and completeness	• General knowledge of security from a policy perspective
Log Review	• Provides historical information on system use, configuration, and modification • Could reveal potential problems and policy deviations	• Knowledge of log formats and ability to interpret and analyze log data • Ability to use automated log analysis and log correlation tools
Ruleset Review	• Reveals holes in ruleset-based security controls	• Knowledge of ruleset formats and structures • Ability to correlate and analyze rulesets from a variety of devices
System Config. Review	• Evaluates the strength of system configuration • Validates that systems are configured in accordance with hardening policy	• Knowledge of secure system configuration, including OS hardening and security policy configuration for a variety of operating systems • Ability to use automated security configuration testing tools
Network Sniffing	• Monitors network traffic on the local segment to capture information such as active systems, operating systems, communication protocols, services, and applications • Verifies encryption of communications	• General Transmission Control Protocol/Internet Protocol (TCP/IP) and networking knowledge • Ability to interpret and analyze network traffic; ability to deploy and use network sniffing tools
File Integrity Checking	• Identifies changes to important files • Identify certain forms of unwanted files, such as well-known attacker tools	• General file system knowledge • Ability to use automated file integrity checking tools and interpret the results

Target Identification and Analysis Techniques (P.24/80)

Technique	Capabilities	Baseline Skill Set
Network Discovery	• Discovers active devices • Identifies communication paths and facilitates determination of network architectures	• General TCP/IP and networking knowledge • Ability to use both passive and active network discovery tools
Network Port and Service Identification	• Discovers active devices • Discovers open ports and associated services/applications	• General TCP/IP and networking knowledge • Knowledge of ports and protocols for a variety of operating systems • Ability to use port scanning tools • Ability to interpret results from tools
Vulnerability Scanning	• Identifies hosts and open ports • Identifies known vulnerabilities (note: has high false positive rates) • Often provides advice on mitigating discovered vulnerabilities	• General TCP/IP and networking knowledge • Knowledge of ports, protocols, services, and vulnerabilities for a variety of operating systems • Ability to use automated vulnerability scanning tools and interpret/analyze the results
Wireless Scanning	• Identifies unauthorized wireless devices within range of the scanners • Discovers wireless signals outside of an organization's perimeter • Detects potential backdoors and other security violations	• General knowledge of computing and radio transmissions in addition to specific knowledge of wireless protocols, services, and architectures • Ability to use automated wireless scanning and sniffing tools

Target Vulnerability Validation Techniques (P.35/80)

Technique	Capabilities	Baseline Skill Set
Password Cracking	• Identifies weak passwords and password policies	• Knowledge of secure password composition and password storage for operating systems • Ability to use automated cracking tools
Penetration Testing	• Tests security using the same methodologies and tools that attackers employ • Verifies vulnerabilities • Demonstrates how vulnerabilities can be exploited iteratively to gain greater access	• Extensive TCP/IP, networking, and OS knowledge • Advanced knowledge of network and system vulnerabilities and exploits • Knowledge of techniques to evade security detection
Social Engineering	• Allows testing of both procedures and the human element (user awareness)	• Ability to influence and persuade people • Ability to remain composed under pressure

Security Assessment Planning (P.42/80)

- Developing a Security Assessment Policy
  - To provide direction and guidance for their security assessments.
- Prioritizing and Scheduling Assessments
  - Decide which systems should undergo assessments and how often these assessments should be done.
- Selecting and Customizing Techniques
- Assessment Logistics
  - Identifying all required resources, including the assessment team.
  - Selecting environments and locations from which to perform the assessment.
  - Acquiring and configuring all necessary technical tools.
- Assessment Plan Development
- Legal Considerations
  - Evaluate potential legal concerns before commencing an assessment, particularly if the assessment involves intrusive tests (e.g., penetration testing) or if the assessment is to be performed by an external entity.
  - Legal departments may review the assessment plan, address privacy concerns, and perform other functions in support of assessment planning.

Security Assessment Execution (P.55/80)

- Coordination
  - Throughout an assessment, it is critical for assessors to coordinate with various entities in the organization. Coordination requirements are determined by the assessment plan or ROE and should be followed accordingly
- Assessing
  - The plan or ROE should be followed unless specific permission to deviate has been obtained, normally in writing, from the original signatory or individual in command
- Analysis
  - The primary goals in conducting analysis are to identify false positives, categorize vulnerabilities, and determine the vulnerabilities' causes.
  - Automated tools can produce a significant number of findings, but these findings often need to be validated to isolate false positives.
  - Assessors may validate vulnerabilities by manually examining the vulnerable system or by using a second automated tool and comparing the results.
- Data Handling
  - Ensure the protection of sensitive information—including system architecture, security configurations, and system vulnerabilities.
  - Ensure proper documentation of requirements for data handling in the assessment plan or ROE, and adhere to their governing policies regarding the handling of system vulnerabilities.

Coordination (P.55/80)

- Stakeholders are aware of the assessment schedule, activities, and potential impacts the assessment may have
  - ต้องแจ้งผู้มีส่วนได้ส่วนเสีย
- The assessment does not take place during upgrades, new technology integration, or other times when the system security is being altered (e.g., testing occurs during maintenance windows or periods of low utilization)
  - ควรทำตอนระบบทำงานปกติ (ไม่อยู่ระหว่างการปรับปรุงหรือเปลี่ยนแปลง ไม่งั้นทำไปก็ไร้ประโยชน์ เพราะไม่ได้สะท้อน Status ของระบบในการใช้งานปกติอย่างที่เราอยากได้)
- Assessors are provided with required levels of access to the facility and systems, as appropriate
- Appropriate personnel such as the CIO, CISO, and ISSO are informed of any critical high-impact vulnerabilities as soon as they are discovered
  - ตรวจเจอช่องโหว่สำคัญๆต้องรีบแจ้ง
- Appropriate individuals are informed (e.g., assessors, incident response team, senior management) in the event of an incident
  - ถ้าเกิดอะไรขึ้นระหว่าง Assessment (เช่น มีการโจมตีจากคนอื่นเกิดขึ้น หรือเกิดอุบัติเหตุ) ต้องรีบแจ้ง

Assessing (P.56/80)

Resistance : Resistance to assessments can come from many sources within an organization, including system and network administrators and end users. Reasons may include fear of losing system or network availability, fear of being reprimanded, inconvenience, and resistance to change.

Lack of Realism : การที่ต้องแจ้งล่วงหน้าเข้าทดสอบระบบ อาจทำให้เกิดผักชีโรยหน้า Staff รีบปรับปรุงแก้ไขระบบให้ดีพร้อมตรวจ ทั้งที่ปล่อยให้แย่มาตั้งนาน บางทีเขาเลยแอบเข้าทดสอบโดยไม่แจ้งล่วงหน้า

Immediate Mitigation : ในระหว่างการตรวจ หากเจอช่องโหว่ Admin อาจอยากขอแก้ไขทันทีแล้วให้เราตรวจซ้ำใหม่ทันที ฟังดูเหมือนจะเป็นสิ่งที่ควรทำ แต่เราต้องอย่าลืมปฏิบัติตาม Change Management Policies and Procedures ซึ่งอาจกำหนดว่าการแก้ไขระบบต้องได้รับการ Approve จากผู้มีอำนาจตัดสินใจก่อน เช่น CAB, C-Level Staff เป็นต้น

Time : การทดสอบบางทีต้องใช้เวลา แต่ Testee มักไม่อยากให้นาน โดยเฉพาะการทดสอบ Production

Resources : Security assessment faces the continual challenge of obtaining and maintaining adequate resources (e.g., a skilled test team and up-to-date hardware and software).

Evolving Technology : Assessors need to stay up to date on tools and testing techniques. Budgets should allow for annual training classes and conferences where assessors can update and refresh their skills.

Operational Impact : Although assessments are planned to prevent or limit operational impact, there is always a chance of accidental or unexpected complications. Every test conducted should be recorded with a timestamp, test type, tool used, commands, the IP address of testing equipment, etc.

Analysis (P.57/80)

Root Cause Analysis (RCA)

- While individual vulnerabilities need to be identified and resolved, identifying the root cause of vulnerabilities is key to improving the organization's overall security posture because a root cause can often be traced to program-level weaknesses. Some common root causes include:
  - Insufficient patch management
  - Insufficient threat management
  - Lack of security baselines
  - Poor integration of security into the system development life cycle
  - Security architecture weaknesses
  - Inadequate incident response procedures
  - Inadequate training
  - Lack of security policies or policy enforcement

A useful resource to reference throughout the analysis phase is the NIST National Vulnerability Database (NVD). NVD is a database that contains information on Common Vulnerabilities and Exposures (CVE), a list of standardized names for known vulnerabilities. The NVD scores vulnerabilities with the Common Vulnerability Scoring System (CVSS) and provides additional information regarding the vulnerability and additional resources to reference for mitigation recommendations (e.g., vendor Web sites).

Data Handling (P.61/80)

Data Collection

- Architecture and Configuration Data
- Assessor Activities

Data Storage

- Storage of data collected during the assessment, including vulnerabilities, analysis results, and mitigation recommendations
- At a minimum, assessors should store the following information to be used for identifying, analyzing, and reporting on the security posture of the organization, and provide an audit trail of testing activities:
  - Assessment plans and ROEs
  - Documentation on system security configuration and network architecture
  - Results from automated tools and other findings
  - Assessment results report
  - Corrective action plan or Plan of Action and Milestones (POA&M).

Data Transmission

- It may be necessary to transmit assessment data, such as system configurations and vulnerabilities, over the network or Internet, and it is important to ensure the security of the data being transmitted to protect it from compromise.
- The assessment plan or ROE should address the requirements of, and process for, transmitting sensitive system information across the network or Internet.

Data Destruction

- Disposal : the act of discarding media with no other sanitization considerations
- Clearing : Overwriting is an example of an acceptable method for clearing media.
- Purging : e.g., executing firmware Secure Erase command (for ATA drives only) and degaussing
- Destruction : Physical destruction, e.g., disintegration, incineration, pulverizing, shredding, and melting

Post-Testing Activities (P.62/80)

Mitigation Recommendations : Outcome ของ RCA for each finding and its security solution

Reporting : Upon completion of analysis, a report should be generated that identifies system, network, and organizational vulnerabilities and their recommended mitigation actions.

- Security testing results can be used in the following ways:
  - As a reference point for corrective action
  - In defining mitigation activities to address identified vulnerabilities
  - As a benchmark for tracking an organization's progress in meeting security requirements
  - To assess the implementation status of system security requirements
  - To conduct cost/benefit analysis for improvements to system security
  - To enhance other life cycle activities, such as risk assessments, C&A, and process improvement efforts
  - To meet reporting requirements, such as those of FISMA.
- Security testing results should be documented and made available to the appropriate staff, which may include the CIO, CISO, and ISSO as well as appropriate program managers or system owners.

Remediation(แก้ไข)/Mitigation(บรรเทา) : การดำเนินการเพื่อแก้ไขหรือบรรเทา

- Testing the remediation recommendation
- POA&M should be coordinated through an organization's configuration control or configuration management board
- Mitigation actions are implemented and verified to ensure their appropriate and accurate implementation.
- Continuously update POA&Ms to identify activities that have been accomplished, partially accomplished, or are pending action by another individual or system.

Example of ROE Template (P.67/80)

1. Introduction

1.1. Purpose

Identifies the purpose of the document as well as the organization being tested, the group conducting the testing (or, if an external entity, the organization engaged to conduct the testing), and the purpose of the security test.

1.2. Scope

Identifies test boundaries in terms of actions and expected outcomes.

1.3. Assumptions and Limitations

Identifies any assumptions made by the organization and the test team. These may relate to any aspect of the test to include the test team, installation of appropriate safeguards for test systems, etc.

1.4. Risks

Inherent risks exist when conducting information security tests—particularly in the case of intrusive tests. This section should identify these risks, as well as mitigation techniques and actions to be employed by the test team to reduce them.

1.5. Document Structure

Outlines the ROE's structure, and describes the content of each section.

Example of ROE Template (2)

2. Logistics

2.1. Personnel

Identifies by name all personnel assigned to the security testing task, as well as key personnel from the organization being tested. Should include a table with all points of contact for the test team, appropriate management personnel, and the incident response team. If applicable, security clearances or comparable background check details should also be provided.

2.2. Test Schedule

Details the schedule of testing, and includes information such as critical tests and milestones. This section should also address hours during which the testing will take place—for example, it may be prudent to conduct technical testing of an operational site during evening hours rather than during peak business periods.

2.3. Test Site

Identifies the location or locations from which testing is authorized. If testing will occur on the organization's site, building and equipment access should be discussed. Physical access should cover requirements such as badges, escorts, and security personnel that the testers may encounter. Equipment access should address areas such as level of access (user or administrator) to the systems and/or network, and physical access to computer rooms or specific racks that these rooms contain. Areas to which the test team will not be given access should be identified here as well. If testing will be conducted from a remote location such as a rented server farm or test lab, details of the test site architecture should be included in this section.

2.4. Test Equipment

Identifies equipment that the test team will use to conduct the information security tests. This section should also identify the method of differentiating between the organization's systems and the systems conducting the testing—for example, if the test team's systems are identified by MAC, keeping track of test systems could be handled through use of network discovery software. In addition to hardware, tools authorized for use on the network should be identified. It would also be appropriate to include a write-up of each tool in an appendix.

Example of ROE Template (3)

3. Communication Strategy

3.1. General Communication

Discusses frequency and methods of communication. For example, identify meeting schedule, locations, and conference call information if appropriate.

3.2. Incident Handling and Response

This section is critical in the event that an incident occurs on the network while testing is in progress. Criteria for halting the information security testing should be provided, as should details on the test team's course of action in the event that a test procedure negatively impacts the network or an adversary attacks the organization while testing is underway. The organization's incident response call tree/chain of command should be provided in a quick-reference format. A process for reinstating the test team and resuming testing should also be provided.

4. Target System/Network

Identifies the systems and/or networks to be tested throughout the information security testing process. Information should include authorized and unauthorized IP addresses or other distinguishing identifiers, if appropriate, for the systems (servers, workstations, firewalls, routers, etc.), operating systems, and any applications to be tested. It is also crucial to identify any system not authorized for testing—this is referred to as the "exclude list."

Example of ROE Template (4)

5. Testing Execution

This section is specific to test type and scope, but should detail allowable and unallowable activities and include a description of the information security testing methodology. If necessary, an assessment plan should be developed that complements the ROE—this could be either an appendix or a separate document.

5.1. Nontechnical Test Components

Identifies nontechnical test activities that will take place, and includes information to help identify the types of policies, procedures, and other documents that should be reviewed. If interviews or site surveys are to be conducted, guidelines should be established for advance approval of the interview list and questions. If physical security of information systems is in the scope of the testing, procedures should be determined and a form—with appropriate signatures and contact information—generated for the test team to show to law enforcement or onsite security personnel in the event that they are questioned.

5.2. Technical Test Components

Includes the type of technical testing to be conducted (e.g., network scanning, discovery, penetration testing); discusses whether files are authorized to be installed, created, modified, and/or executed to facilitate testing; and explains the required actions for those files once testing is completed. Any additional information regarding the technical testing of the organization's systems and networks should also be included in this section. Significant detail should be included on what activities will occur on the target network to ensure that all parties are aware of what is authorized and to be expected as a result of the testing.

5.3. Data Handling

Identifies guidelines for gathering, storing, transmitting, and destroying test data, and establishes detailed, unambiguous requirements for data handling. Keep in mind that data results from any type of information security test will identify vulnerabilities that an adversary can exploit, and should be considered sensitive.

Example of ROE Template (5)

6. Reporting

Details reporting requirements and the report deliverables expected to be provided throughout the testing process and at its conclusion. Minimum information to be provided in each report (e.g., vulnerabilities and recommended mitigation techniques) and the frequency with which the reports will be delivered (e.g., daily status reports) should be included. A template may be provided as an appendix to the ROE to demonstrate report format and content.

7. Signature Page

Designed to identify accountable parties and ensure that they know and understand their responsibilities throughout the testing process. At a minimum, the test team leader and the organization's senior management (CSO, CISO, CIO, etc.) should sign the ROE stating that they understand the test's scope and boundaries.

Examples of Security Testing Tools

Table A-1. BackTrack Toolkit Sample

Security Testing Technique	Security Testing Tool
Review	
Network Sniffing	Dsniff, Ettercap, Kismet, Mailsnarf, Msgsnarf, Ntop, Phoss, SinFP, SMB Sniffer, and Wireshark
File Integrity Checking	Autopsy, Foremost, RootkitHunter, and Sleuthkit
Target Identification and Analysis	
Application Security Testing	CIRT Fuzzer, Fuzzer 1.2, NetSed, Paros Proxy, and Peach
Network Discovery	Autonomous System Scanner, Ettercap, Firewalk, Netdiscover, Netenum, Netmask, Nmap, P0f, Tctrace, and Umit
Network Port and Service Identification	Amap, AutoScan, Netdiscover, Nmap, P0f, Umit, and UnicornScan
Vulnerability Scanning	Firewalk, GFI LANguard, Hydra, Metasploit, Nmap, Paros Proxy, Snort, and SuperScan
Wireless Scanning	Airsnarf, Airsnort, BdAddr, Bluesnarfer, Btscanner, FakeAP, GFI LANguard, Kismet, and WifiTAP
Target Vulnerability Validation	
Password Cracking	Hydra, John the Ripper, RainbowCrack, Rcrack, SIPcrack, SIPdump, TFTP-Brute, THC PPTP, VNCrack, and WebCrack
Remote Access Testing	IKEProbe, IKE-Scan, PSK-Crack, and VNC_bypauth
Penetration Testing	Driftnet, Dsniff, Ettercap, Kismet, Metasploit, Nmap, Ntop, SinFP, SMB Sniffer, and Wireshark

Table A-2. Knoppix STD Toolkit Sample

Security Testing Technique	Security Testing Tool
Review	
Network Sniffing	Dsniff, Ettercap, Ethereal, Filesnarf, Kismet, Mailsnarf, Msgsnarf, Ngrep, Ntop, TCPdump, and Webspy
File Integrity Checking	Autopsy, Biew, Bsed, Coreography, Foremost, Hashdig, Rifiuti, and Sleuthkit
Target Identification and Analysis	
Application Security Testing	NetSed
Network Discovery	Cryptcat, Ettercap, Firewalk, Netcat, Nmap, and P0f
Network Port and Service Identification	Amap, Netcat, Nmap, and P0f
Vulnerability Scanning	Exodus, Firewalk, Nmap, and Snort
Wireless Scanning	Airsnarf, Airsnort, GPSdrive, Kismet, and MACchanger
Target Vulnerability Validation	
Password Cracking	Allwords2, chntpw, Cisilia, Djohn, Hydra, John the Ripper, and Rcrack
Remote Access Testing	Apache Server, IKE-Scan, Net-SNMP, SSHD, TFTPD, and VNC Server
Penetration Testing	Driftnet, Dsniff, Ethereal, Ettercap, Kismet, Nessus, Netcat, Ngrep, Nmap, Ntop, and TCPdump

รายละเอียดอื่นๆที่น่าสนใจ

Appendix C—Application Security Testing and Examination (P.70/80)

Appendix D—Remote Access Testing (P.72/80)

Appendix E—Resources (P.74/80)

Appendix F—Glossary (P.76/80)

Appendix G—Acronyms and Abbreviations (P.78/80)